

Useful LDAP queries for Windows Active Directory pentesting

 web.archive.org/web/20231226230414/https://podalirius.net/en/articles/useful-ldap-queries-for-windows-active-directory-pentesting

Podalirius

April 2, 2023

Useful LDAP queries for Windows Active Directory pentesting

```
[DC=LAB,DC=local]> query (sAMAccountType=805306369) select
[>] CN=DC01,OU=Domain Controllers,DC=LAB,DC=local
[>] CN=PC01,OU=LAPS Managed Computers,DC=LAB,DC=local
[>] CN=SQL01,CN=Computers,DC=LAB,DC=local
[DC=LAB,DC=local]> █
```

Table of contents :

Introduction

In Windows Active Directory domains, a large amount of information is stored in LDAP. This information contains in particular the rights of users, groups, subnets, machines attached to the domain, etc.

Note: Some queries use special comparison operators, (especially on the `userAccountControl`), the descriptions of which are:

Operators	OID	Description
LDAP_MATCHING_RULE_BIT_AND	1.2.840.113556.1.4.803	Bitwise “AND” operation
LDAP_MATCHING_RULE_BIT_OR	1.2.840.113556.1.4.804	Bitwise “OR” operation

Operators	OID	Description
LDAP_MATCHING_RULE_TRANSITIVE_EVAL	1.2.840.113556.1.4.1941	Recursive search of a link attribute. (See documentation)
LDAP_MATCHING_RULE_DN_WITH_DATA	1.2.840.113556.1.4.2253	Match on portions of values of syntax Object(DN-String) and Object(DN-Binary).

In the rest of this article, I offer you a list of LDAP queries that are very useful during a pentest.

Users

List all users

To do this we select all the users ((objectClass=user)) and all the people ((objectClass=person)) of the LDAP:

```
(&(objectCategory=person)(objectClass=user))
```

List of all kerberoastables users

To do this we select all the users ((objectClass=user)) having a Service Principal Name (SPN) defined ((servicePrincipalName=*)) and we remove from our results:

- The user krbtgt (which by definition has an SPN) with the filter (!(cn=krbtgt)).
- Disabled users, with the filter (!(userAccountControl:1.2.840.113556.1.4.803:=2))

Which gives us:

```
(&(objectClass=user)(servicePrincipalName=*)(!(cn=krbtgt))(!(userAccountControl:1.2.840.113556.1.4.803:=2)))
```

List of all asrep-roastables users

To do this we select all the users ((objectClass=user)) that have “*Do not require Kerberos preauthentication*” flag set in their userAccountControl:

```
(&(objectClass=user)(userAccountControl:1.2.840.113556.1.4.803:=4194304))
```

Find all Users that need to change password on next login.

```
(&(objectCategory=user)(pwdLastSet=0))
```

Find all Users that are almost Locked-Out

```
(&(objectCategory=user)(badPwdCount>=4))
```

Find all Users with *pass* or *pwd* in their description

```
(&(objectCategory=user)(|(description=*pass*)(description=*pwd*)))
```

List of all users protected by adminCount

The [adminCount](#) attribute specifies that a given object has had its access control lists (ACLs) changed to a more secure value by the Active Directory system because it is a member of one of the administrative groups, either directly or transitively.

```
(&(objectCategory=user)(adminCount=1))
```

Groups

List all groups

List of all groups protected by adminCount

The [adminCount](#) attribute specifies that a given object has had its access control lists (ACLs) changed to a more secure value by the Active Directory system because it is a member of one of the administrative groups, either directly or transitively.

```
(&(objectCategory=group)(adminCount=1))
```

Services

Listing all servicePrincipalName

```
(servicePrincipalName=*)
```

Listing specific services from their servicePrincipalName

To list specific services, we can use the beginning of the servicePrincipalName attribute:

```
(servicePrincipalName=http/*)
```

Here is a few examples of servicePrincipalName:

- ldap/DC01.LAB.local
- kadmin/changepw (of kerberos service CN=krbtgt,CN=Users,DC=LAB,DC=local)
- MSSQLSvc/DC01.LAB.local

Computers

Listing all computers with a given Operating System

For example to list all the machines under Windows XP:

```
(&(objectCategory=Computer)(operatingSystem=Windows XP*))
```

With operatingSystem in:

- Windows Server 2022*
- Windows Server 2019*
- Windows Server 2016*
- Windows Server 2008*
- Windows 11*
- Windows 10*
- Windows 8*
- Windows 7*
- Windows Vista*
- Windows XP*
- Windows Server 2003*
- Windows 2000*

Find all Workstations

```
(sAMAccountType=805306369)
```

Find all computers having a KeyCredentialLink

This is useful to check for shadow credentials on machine accounts:

```
(&(objectClass=computer)(msDS-KeyCredentialLink=*))
```

References

https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-drsr/ed5db046-d9f7-4da4-884c-e14b6bcf5471